```
CREATE DATABASE IF NOT EXISTS jones_db;
USE jones_db;
CREATE TABLE IF NOT EXISTS users (
  id INT AUTO_INCREMENT PRIMARY KEY,
  fullname VARCHAR(100) NOT NULL,
  email VARCHAR(100) NOT NULL UNIQUE,
  password VARCHAR(255) NOT NULL,
  role VARCHAR(10) NOT NULL DEFAULT 'user',
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
CREATE TABLE IF NOT EXISTS books (
  id INT AUTO_INCREMENT PRIMARY KEY,
  user_id INT NOT NULL,
  title VARCHAR(150) NOT NULL,
  author VARCHAR(100) NOT NULL,
  book_condition VARCHAR(20) NOT NULL,
  FOREIGN KEY (user_id) REFERENCES users(id) ON DELETE CASCADE
);
```

```
<?php
$conn = mysqli_connect("localhost", "root", "", "jones_db");
if (!$conn) {
    die("Connection failed: " . mysqli_connect_error());
}
?>
```

```
<?php
session_start();
function requireLogin() {
    if (!isset($_SESSION["user_id"])) {
        header("Location: login.php");
        exit();
    }
}
function requireAdmin() {
    requireLogin();
    if ($_SESSION["role"] != "admin") {
        header("Location: dashboard.php?denied=1");
        exit();
    }
}
?>
```

```
<!DOCTYPE html>
<html>
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <title><?php echo $pageTitle; ?> - Jones</title>
  <link rel="stylesheet" href="style.css">
</head>
<body>
<?php if (isset($_SESSION["user_id"])) { ?>
<div class="nav">
  <a href="dashboard.php">Home</a>
  <a href="books.php">Books</a>
  <?php if ($_SESSION["role"] == "admin") { ?><a href="users.php">Users</a><?php } ?>
  <a href="logout.php">Log out (<?php echo htmlspecialchars($_SESSION["fullname"]); ?>)</a>
</div>
<?php } ?>
```

```
<?php
include "db.php";
$password = password_hash("admin123", PASSWORD_DEFAULT);
$check = mysqli_query($conn, "SELECT * FROM users WHERE email = 'admin@jones.com'");
if (mysqli_num_rows($check) > 0) {
    echo "Admin already exists.";
} else {
    mysqli_query($conn, "INSERT INTO users (fullname, email, password, role)
                         VALUES ('Admin', 'admin@jones.com', '$password', 'admin')");
    echo "Admin created. Email: admin@jones.com | Password: admin123";
}
?>
```

```
<?php
include "db.php";
include "auth.php";
$fullname = "";
$email = "";
$error = "";
$success = "";
if (isset($_POST["register"])) {
    $fullname = trim($_POST["fullname"]);
    $email = trim($_POST["email"]);
    $password = $_POST["password"];
    $confirm = $_POST["confirm"];
    if ($fullname == "" || $email == "" || $password == "") {
        $error = "Please fill in all fields.";
    } elseif (!filter_var($email, FILTER_VALIDATE_EMAIL)) {
        $error = "Please enter a valid email.";
    } elseif (strlen($password) < 6) {
        $error = "Password must be at least 6 characters.";
    } elseif ($password != $confirm) {
        $error = "Passwords do not match.";
    } else {
        $safeName = mysqli_real_escape_string($conn, $fullname);
        $safeEmail = mysqli_real_escape_string($conn, $email);
        $check = mysqli_query($conn, "SELECT * FROM users WHERE email = '$safeEmail'");
        if (mysqli_num_rows($check) > 0) {
            $error = "This email is already registered.";
        } else {
            $hashed = password_hash($password, PASSWORD_DEFAULT);
            mysqli_query($conn, "INSERT INTO users (fullname, email, password)
```

```
                                VALUES ('$safeName', '$safeEmail', '$hashed')");
            $success = "Registered successfully! You can now sign in.";
            $fullname = "";
            $email = "";
        }
    }
}
$pageTitle = "Register";
include "header.php";
?>
<div class="container">
  <h1>Jones</h1>
  <p class="tagline">Secondhand book swap</p>
  <h2>Register</h2>
  <form method="POST" action="register.php">
    <label>Full Name</label>
    <input type="text" name="fullname" value="<?php echo htmlspecialchars($fullname); ?>">
    <label>Email</label>
    <input type="email" name="email" value="<?php echo htmlspecialchars($email); ?>">
    <label>Password</label>
    <input type="password" name="password">
    <label>Confirm Password</label>
    <input type="password" name="confirm">
    <button type="submit" name="register">Register</button>
  </form>
  <p class="fail"><?php echo $error; ?></p>
  <p class="success"><?php echo $success; ?></p>
  <p class="link">Already have an account? <a href="login.php">Sign in here</a></p>
</div>
</body>
</html>

<?php
include "db.php";
include "auth.php";
if (isset($_SESSION["user_id"])) {
    header("Location: dashboard.php");
    exit();
}
$email = "";
$error = "";
if (isset($_POST["login"])) {
    $email = trim($_POST["email"]);
    $password = $_POST["password"];
    $safeEmail = mysqli_real_escape_string($conn, $email);
    $result = mysqli_query($conn, "SELECT * FROM users WHERE email = '$safeEmail'");
    $user = mysqli_fetch_assoc($result);
    if ($user && password_verify($password, $user["password"])) {
        $_SESSION["user_id"] = $user["id"];
        $_SESSION["fullname"] = $user["fullname"];
        $_SESSION["role"] = $user["role"];
        header("Location: dashboard.php");
        exit();
    } else {
        $error = "Wrong email or password.";
    }
}
$pageTitle = "Sign In";
include "header.php";
?>
<div class="container">
  <h1>Jones</h1>
  <p class="tagline">Secondhand book swap</p>
  <h2>Sign In</h2>
  <form method="POST" action="login.php">
    <label>Email</label>
    <input type="email" name="email" value="<?php echo htmlspecialchars($email); ?>">
    <label>Password</label>
    <input type="password" name="password">
    <button type="submit" name="login">Sign In</button>
  </form>
  <p class="fail"><?php echo $error; ?></p>
  <p class="link">No account yet? <a href="register.php">Register here</a></p>
</div>
</body>
</html>

<?php
session_start();
session_destroy();
header("Location: login.php");
exit();
?>

<?php
include "db.php";
include "auth.php";
requireLogin();
$uid = (int)$_SESSION["user_id"];
$row = mysqli_fetch_assoc(mysqli_query($conn, "SELECT COUNT(*) AS total FROM books WHERE user_id = $uid"));
$myBooks = $row["total"];
$pageTitle = "Home";
include "header.php";
?>
<div class="container">
  <h2>Welcome, <?php echo htmlspecialchars($_SESSION["fullname"]); ?>!</h2>
  <p class="tagline">Role: <?php echo $_SESSION["role"]; ?></p>
  <?php if (isset($_GET["denied"])) { ?>
    <p class="fail">Access denied. You are not allowed to open that page.</p>
  <?php } ?>
  <p>Your books: <b><?php echo $myBooks; ?></b></p>
  <?php if ($_SESSION["role"] == "admin") {
      $row = mysqli_fetch_assoc(mysqli_query($conn, "SELECT COUNT(*) AS total FROM users")); ?>
```

```
    <p>Total users: <b><?php echo $row["total"]; ?></b></p>
  <?php } ?>
</div>
</body>
</html>

<?php
include "db.php";
include "auth.php";
requireLogin();
$message = "";
if (isset($_GET["msg"])) {
    $message = $_GET["msg"];
}
$where = "";
if ($_SESSION["role"] != "admin") {
    $where = "WHERE books.user_id = " . (int)$_SESSION["user_id"];
}
$result = mysqli_query($conn, "SELECT books.*, users.fullname FROM books
                               JOIN users ON books.user_id = users.id $where
                               ORDER BY books.id DESC");
$pageTitle = "Books";
include "header.php";
?>
<div class="container wide">
  <div class="top-row">
    <h2>Books</h2>
    <a class="add-link" href="book_form.php">+ Add Book</a>
  </div>
  <p class="success"><?php echo htmlspecialchars($message); ?></p>
  <table>
    <tr><th>Title</th><th>Author</th><th>Condition</th><th>Owner</th><th>Actions</th></tr>
    <?php while ($book = mysqli_fetch_assoc($result)) { ?>
    <tr>
      <td><?php echo htmlspecialchars($book["title"]); ?></td>
      <td><?php echo htmlspecialchars($book["author"]); ?></td>
      <td><?php echo $book["book_condition"]; ?></td>
      <td><?php echo htmlspecialchars($book["fullname"]); ?></td>
      <td>
        <a class="small" href="book_form.php?id=<?php echo $book["id"]; ?>">Edit</a>
        <form method="POST" action="book_delete.php" onsubmit="return confirm('Delete this book?');">
          <input type="hidden" name="id" value="<?php echo $book["id"]; ?>">
          <button type="submit" class="small red">Delete</button>
        </form>
      </td>
    </tr>
    <?php } ?>
  </table>
</div>
</body>
</html>

<?php
include "db.php";
include "auth.php";
requireLogin();
$conditions = array("New", "Good", "Fair", "Worn");
$id = 0;
if (isset($_GET["id"])) {
    $id = (int)$_GET["id"];
}
if (isset($_POST["id"])) {
    $id = (int)$_POST["id"];
}
$title = "";
$author = "";
$condition = "Good";
$error = "";
if ($id > 0) {
    $result = mysqli_query($conn, "SELECT * FROM books WHERE id = $id");
    $book = mysqli_fetch_assoc($result);
    if (!$book) {
        header("Location: books.php");
        exit();
    }
    if ($_SESSION["role"] != "admin" && $book["user_id"] != $_SESSION["user_id"]) {
        header("Location: dashboard.php?denied=1");
        exit();
    }
    $title = $book["title"];
    $author = $book["author"];
    $condition = $book["book_condition"];
}
if (isset($_POST["save"])) {
    $title = trim($_POST["title"]);
    $author = trim($_POST["author"]);
    $condition = $_POST["condition"];
    if (!in_array($condition, $conditions)) {
        $condition = "Good";
    }
    if ($title == "" || $author == "") {
        $error = "Please enter the title and author.";
    } else {
        $t = mysqli_real_escape_string($conn, $title);
        $a = mysqli_real_escape_string($conn, $author);
        if ($id > 0) {
            mysqli_query($conn, "UPDATE books SET title = '$t', author = '$a',
                                 book_condition = '$condition' WHERE id = $id");
        } else {
            $uid = (int)$_SESSION["user_id"];
            mysqli_query($conn, "INSERT INTO books (user_id, title, author, book_condition)
                                 VALUES ($uid, '$t', '$a', '$condition')");
        }
```

```
        header("Location: books.php?msg=Book saved.");
        exit();
    }
}
$pageTitle = ($id > 0) ? "Edit Book" : "Add Book";
include "header.php";
?>
<div class="container">
  <h2><?php echo $pageTitle; ?></h2>
  <form method="POST" action="book_form.php">
    <input type="hidden" name="id" value="<?php echo $id; ?>">
    <label>Title</label>
    <input type="text" name="title" value="<?php echo htmlspecialchars($title); ?>">
    <label>Author</label>
    <input type="text" name="author" value="<?php echo htmlspecialchars($author); ?>">
    <label>Condition</label>
    <select name="condition">
      <?php foreach ($conditions as $c) { ?>
        <option <?php if ($condition == $c) echo "selected"; ?>><?php echo $c; ?></option>
      <?php } ?>
    </select>
    <button type="submit" name="save">Save Book</button>
  </form>
  <p class="fail"><?php echo $error; ?></p>
  <p class="link"><a href="books.php">Back to books</a></p>
</div>
</body>
</html>

<?php
include "db.php";
include "auth.php";
requireLogin();
$id = 0;
if (isset($_POST["id"])) {
    $id = (int)$_POST["id"];
}
$result = mysqli_query($conn, "SELECT * FROM books WHERE id = $id");
$book = mysqli_fetch_assoc($result);
if ($book && ($_SESSION["role"] == "admin" || $book["user_id"] == $_SESSION["user_id"])) {
    mysqli_query($conn, "DELETE FROM books WHERE id = $id");
    header("Location: books.php?msg=Book deleted.");
} else {
    header("Location: dashboard.php?denied=1");
}
exit();
?>

<?php
include "db.php";
include "auth.php";
requireAdmin();
$message = "";
if (isset($_GET["msg"])) {
    $message = $_GET["msg"];
}
$result = mysqli_query($conn, "SELECT * FROM users ORDER BY id ASC");
$pageTitle = "Users";
include "header.php";
?>
<div class="container wide">
  <div class="top-row">
    <h2>User Management</h2>
    <a class="add-link" href="user_form.php">+ Add User</a>
  </div>
  <p class="success"><?php echo htmlspecialchars($message); ?></p>
  <table>
    <tr><th>ID</th><th>Name</th><th>Email</th><th>Role</th><th>Registered</th><th>Actions</th></tr>
    <?php while ($user = mysqli_fetch_assoc($result)) { ?>
    <tr>
      <td><?php echo $user["id"]; ?></td>
      <td><?php echo htmlspecialchars($user["fullname"]); ?></td>
      <td><?php echo htmlspecialchars($user["email"]); ?></td>
      <td><?php echo $user["role"]; ?></td>
      <td><?php echo $user["created_at"]; ?></td>
      <td>
        <a class="small" href="user_form.php?id=<?php echo $user["id"]; ?>">Edit</a>
        <?php if ($user["id"] != $_SESSION["user_id"]) { ?>
        <form method="POST" action="user_delete.php" onsubmit="return confirm('Delete this user and their books?');">
          <input type="hidden" name="id" value="<?php echo $user["id"]; ?>">
          <button type="submit" class="small red">Delete</button>
        </form>
        <?php } ?>
      </td>
    </tr>
    <?php } ?>
  </table>
</div>
</body>
</html>

<?php
include "db.php";
include "auth.php";
requireAdmin();
$id = 0;
if (isset($_GET["id"])) {
    $id = (int)$_GET["id"];
}
if (isset($_POST["id"])) {
    $id = (int)$_POST["id"];
}
$fullname = "";
```

```
$email = "";
$role = "user";
$error = "";
$isMe = false;
if ($id > 0) {
    $result = mysqli_query($conn, "SELECT * FROM users WHERE id = $id");
    $user = mysqli_fetch_assoc($result);
    if (!$user) {
        header("Location: users.php");
        exit();
    }
    $isMe = ($id == $_SESSION["user_id"]);
    $fullname = $user["fullname"];
    $email = $user["email"];
    $role = $user["role"];
}
if (isset($_POST["save"])) {
    $fullname = trim($_POST["fullname"]);
    $email = trim($_POST["email"]);
    $password = $_POST["password"];
    if ($isMe) {
        $role = "admin";
    } elseif ($_POST["role"] == "admin") {
        $role = "admin";
    } else {
        $role = "user";
    }
    if ($fullname == "" || $email == "") {
        $error = "Please fill in the name and email.";
    } elseif (!filter_var($email, FILTER_VALIDATE_EMAIL)) {
        $error = "Please enter a valid email.";
    } elseif (($id == 0 || $password != "") && strlen($password) < 6) {
        $error = "Password must be at least 6 characters.";
    } else {
        $n = mysqli_real_escape_string($conn, $fullname);
        $e = mysqli_real_escape_string($conn, $email);
        $check = mysqli_query($conn, "SELECT * FROM users WHERE email = '$e' AND id != $id");
        if (mysqli_num_rows($check) > 0) {
            $error = "This email is already used by another user.";
        } else {
            if ($id > 0) {
                mysqli_query($conn, "UPDATE users SET fullname = '$n', email = '$e', role = '$role' WHERE id = $id");
                if ($password != "") {
                    $hashed = password_hash($password, PASSWORD_DEFAULT);
                    mysqli_query($conn, "UPDATE users SET password = '$hashed' WHERE id = $id");
                }
                if ($isMe) {
                    $_SESSION["fullname"] = $fullname;
                }
            } else {
                $hashed = password_hash($password, PASSWORD_DEFAULT);
                mysqli_query($conn, "INSERT INTO users (fullname, email, password, role)
                                     VALUES ('$n', '$e', '$hashed', '$role')");
            }
            header("Location: users.php?msg=User saved.");
            exit();
        }
    }
}
$pageTitle = ($id > 0) ? "Edit User" : "Add User";
include "header.php";
?>
<div class="container">
  <h2><?php echo $pageTitle; ?></h2>
  <form method="POST" action="user_form.php">
    <input type="hidden" name="id" value="<?php echo $id; ?>">
    <label>Full Name</label>
    <input type="text" name="fullname" value="<?php echo htmlspecialchars($fullname); ?>">
    <label>Email</label>
    <input type="email" name="email" value="<?php echo htmlspecialchars($email); ?>">
    <label>Password <?php if ($id > 0) echo "(leave blank to keep the old one)"; ?></label>
    <input type="password" name="password">
    <label>Role</label>
    <select name="role" <?php if ($isMe) echo "disabled"; ?>>
      <option value="user" <?php if ($role == "user") echo "selected"; ?>>user</option>
      <option value="admin" <?php if ($role == "admin") echo "selected"; ?>>admin</option>
    </select>
    <button type="submit" name="save">Save User</button>
  </form>
  <p class="fail"><?php echo $error; ?></p>
  <p class="link"><a href="users.php">Back to users</a></p>
</div>
</body>
</html>

<?php
include "db.php";
include "auth.php";
requireAdmin();
$id = 0;
if (isset($_POST["id"])) {
    $id = (int)$_POST["id"];
}
if ($id == $_SESSION["user_id"]) {
    header("Location: users.php?msg=You cannot delete your own account.");
} else {
    mysqli_query($conn, "DELETE FROM users WHERE id = $id");
    header("Location: users.php?msg=User deleted.");
}
exit();
?>

body {
```

```
  font-family: Arial, sans-serif;
  background-color: #e8f0ee;
  margin: 0;
}
.container {
  width: 350px;
  margin: 40px auto;
  background-color: white;
  padding: 25px;
  border-radius: 8px;
  box-shadow: 0 2px 8px gray;
}
.wide {
  width: 850px;
  max-width: 90%;
}
h1 {
  text-align: center;
  color: #14302c;
  margin-top: 0;
}
.tagline {
  text-align: center;
  color: gray;
}
label {
  display: block;
  margin-top: 12px;
  font-weight: bold;
}
input[type="text"], input[type="email"], input[type="password"], select {
  width: 100%;
  padding: 8px;
  margin-top: 5px;
  border: 1px solid #aaa;
  border-radius: 4px;
  box-sizing: border-box;
}
button {
  width: 100%;
  padding: 10px;
  margin-top: 20px;
  background-color: #14302c;
  color: white;
  border: none;
  border-radius: 4px;
  font-size: 16px;
  cursor: pointer;
}
.fail {
  color: red;
  text-align: center;
}
.success {
  color: green;
  text-align: center;
}
.link {
  text-align: center;
}
.nav {
  background-color: #14302c;
  padding: 12px 20px;
}
.nav a {
  color: white;
  margin-right: 18px;
  text-decoration: none;
  font-weight: bold;
}
table {
  width: 100%;
  border-collapse: collapse;
}
th, td {
  border: 1px solid #ccc;
  padding: 8px;
  text-align: left;
  font-size: 14px;
}
th {
  background-color: #14302c;
  color: white;
}
td form {
  display: inline;
}
.small {
  display: inline-block;
  width: auto;
  margin: 0;
  padding: 5px 10px;
  font-size: 13px;
  background-color: #14302c;
  color: white;
  text-decoration: none;
  border-radius: 4px;
}
.red {
  background-color: #b3261e;
}
.add-link {
  background-color: #e8b923;
```

```
  color: black;
  padding: 8px 14px;
  text-decoration: none;
  border-radius: 4px;
  font-weight: bold;
}
.top-row {
  display: flex;
  justify-content: space-between;
  align-items: center;
}
```